

项目 信息收集

实验单元2： 主动信息收集

2.1 实训说明

2.1.1 实训目的

学会活跃主机扫描、操作系统指纹识别、端口扫描、服务指纹识别和 web 敏感目录扫描方法。

2.1.2 背景知识

- 1. 了解主动信息收集的流程和方法。

2.1.3 实习时长

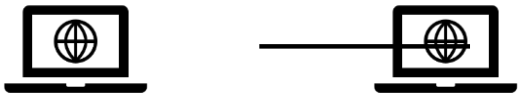
2 个学时

2.2 实训环境

2.2.1 实训器材

Kali Linux 虚拟机、Metasploitable2-Linux 虚拟机。

2.2.2 网络结构



Kali Linux (192.168.159.131) Metasploitable2-Linux (192.168.159.190)

本实验中，Metasploitable2-Linux 与 Kali Linux 在同一网段。

批注 [y1]: 注意：下文提到的 192.168.159.190 的地方需要换成你所部署的 Metasploitable2-Linux 所分配的 ip。提到的 192.168.159.0 网段的地方需要换成你所部署的 Metasploitable2-Linux 所在的网段。


```
root@kali: ~  
File Actions Edit View Help  
[root@kali]~# /usr/share/kali-menu/helper-scripts/metasploit-framework.sh  
[i] Database already started  
[i] The database appears to be already configured, skipping initialization  
Metasploit tip: Use the analyze command to suggest runnable modules for hosts  
*Neutrino_Cannon*PrettyBeefy*PostalTime*binbash*deadastronauts*EvilBunnyWrote  
*LIT*Mail.ru*() { ;;}; echo vulnerable*  
*Team sorcerer*ADACTF*BisonSquad*socialdistancing*LeukeTeamNaam*OWASP Moncton  
*Alegori*exit*Vampire Bunnies*APT593*  
*QuePasaZombiesAndFriends*NetSecBG*coincoin*ShroomZ*Slow Coders*Scavenger Sec  
urity*Bruh*NoTeamName*Terminal Cult*  
*edspiner*BFG*MagentaHats*0x01DA*Kaczuski*AlphaPwners*FILAHA*Raffaela*HackSu  
rYvette*outout*HackSouth*Corax*yeeb0iz*  
*SKUA*Cyber COBRA*flaghunters*0xCD*AI Generated*CSEC*p3nnm3d*IFS*CTF_Circle*I  
nnotecLabs*baadf00d*BitSwitchers*0xnoobs*  
*ItPwns - Intergalactic Team of PWNers*PCCsquared*fr334aks*runCMD*0x194*Kapit  
al Krakens*ReadyPlayer1337*Team 443*
```

```
msf6 > search scanner/discovery  
Matching Modules  
# Name Disclosure Date Rank Check Description  
0 auxiliary/scanner/discovery/arp_sweep normal No ARP Sweep Local Network Discovery  
1 auxiliary/scanner/discovery/empty_udp normal No UDP Empty Prober  
2 auxiliary/scanner/discovery/ipv6_multicast_ping normal No IPv6 Link Local/Node Local Ping Discovery  
3 auxiliary/scanner/discovery/ipv6_neighbor normal No IPv6 Local Neighbor Discovery  
4 auxiliary/scanner/discovery/ipv6_neighbor_router_advertisement normal No IPv6 Local Neighbor Router Advertisement Discovery  
5 auxiliary/scanner/discovery/udp_probe normal No UDP Service Prober  
6 auxiliary/scanner/discovery/udp_sweep normal No UDP Service Sweeper  
Interact with a module by name or index. For example info 6, use 6 or use auxiliary/scanner/discovery/udp_sweep
```

其中，arp_sweep 发现活跃主机的原理是使用 ARP 请求枚举本地局域网络中的所有活跃主机。ARP（Address Resolution Protocol）是一种地址解析协议，它的作用是将 IP 地址转换成 MAC 地址，以便能实现消息的发送与接收，具体的转换过程是通过广播 ARP 请求方式查询指定 IP 的 MAC 地址，IP 符合查询的主机将自己的 MAC 地址回应，因此，能通过发送 ARP 请求来获取同一子网上的活跃主机信息。

在使用 Metasploit 的 arp_sweep 模块进行活跃主机扫描时，先使用 use 命令启用该模块 useauxiliary/scanner/discovery/arp_sweep。

```
msf6 > use auxiliary /scanner/discovery/arp_sweep  
Matching Modules  
# Name Disclosure Date Rank Check Description  
0 auxiliary/scanner/discovery/arp_sweep normal No ARP Sweep Local Network Discovery  
Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/discovery/arp_sweep  
[*] Using auxiliary/scanner/discovery/arp_sweep  
msf6 auxiliary(scanner/discovery/arp_sweep) >
```

然后使用 set 命令设置扫描网段和线程数，然后执行 run 命令开始扫描。

```
msf6 auxiliary(scanner/discovery/arp_sweep) > set rhost 192.168.159.190/24
rhost => 192.168.159.190/24
msf6 auxiliary(scanner/discovery/arp_sweep) > set threads 50
threads => 50
msf6 auxiliary(scanner/discovery/arp_sweep) > run

[+] 192.168.159.1 appears to be up (VMware, Inc.).
[+] 192.168.159.2 appears to be up (VMware, Inc.).
[+] 192.168.159.190 appears to be up (VMware, Inc.).
[+] 192.168.159.254 appears to be up (VMware, Inc.).
[*] Scanned 256 of 256 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/discovery/arp_sweep) >
```

批注 [y3]: 注意：set rhost <你的虚拟机所在 ip 网段>

Nmap 通过启用“-sP”参数也能够实现活跃主机扫描。以目标所在的网段为例，扫描整个网段 192.168.159.1-192.168.159.255 共 255 个 IP 地址的具体命令为 nmap -sP 192.168.159.0/24，“-sP”选项在默认情况下，会发送一个 ICMP 回声请求和一个 TCP 报文到目标端口，只进行 Ping，然后显现出在线（做出响应）的主机，使用该选项扫描可以轻易地获取目标信息而不会被轻易发现。

批注 [y4]: 注意：这个网段是当前你的虚拟机网卡所在的网段。

```
(kali@kali)-[~/桌面]
$ nmap -sP 192.168.159.0/24
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-27 15:32 CST
Nmap scan report for 192.168.159.1
Host is up (0.0039s latency).
Nmap scan report for 192.168.159.2
Host is up (0.0033s latency).
Nmap scan report for 192.168.159.131
Host is up (0.0036s latency).
Nmap scan report for 192.168.159.190
Host is up (0.0035s latency).
Nmap done: 256 IP addresses (4 hosts up) scanned in 3.01 seconds
```

2.3.3 操作系统指纹识别

操作系统指纹识别指的是识别某台设备上运行的操作系统的类型，例如操作系统指纹为 Linux(kernel 2.4)，代表该操作系统为 Linux 系统，内核版本为 2.4。识别的方法是通过分析设备在网络发送的数据包中协议的标记、选项等数据推断发送数据包的操作系统。通过操作系统指纹识别可以获取操作系统的类型，这为后续渗透测试中漏洞利用奠定了基础，因为许多漏洞都强依赖于操作系统的版本。

p0f 是一款被动探测操作系统指纹的工具，它通过嗅探方式分析网络数据包来判断操作系统类型，不会干扰双方的正常通信。此外，它还可以用于分析 NAT、

负载均衡、应用代理等。该工具可以运行在前台也可以后台运行。p0f 探测的原理是利用 TCP 的 SYN 数据包实现操作系统的被动检测，能够正确地识别目标系统类型。由于在探测过程中不向目标系统发送任何数据，只被动地接受目标系统的数据进行分析，因此它几乎无法被检测到。

p0f 在 kali 中没有默认安装，因此在使用前需通过命令 `sudo apt-get install p0f` 安装 P0f

使用 `ifconfig` 查看 Kali 的网卡配置信息，可看到启用的网卡名称为 `eth0`。

```
ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.159.131 netmask 255.255.255.0 broadcast 192.168.159.255
    inet6 fe80::20c:29ff:fe39:82ea prefixlen 64 scopeid 0<link>
    ether 00:0c:29:39:82:ea txqueuelen 1000 (Ethernet)
    RX packets 98003 bytes 123953487 (118.2 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 35243 bytes 4302464 (4.1 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 65234 bytes 32988978 (31.4 MiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 65234 bytes 32988978 (31.4 MiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

使用 p0f 的“-i”参数设定监听网卡为 `eth0`，“-p”参数设置监听模式为混杂模式，开始监听。

```
(root@kali)~[/home/kali]
# p0f -i eth0 -p
p0f 3.09b by Michal Zalewski <lcantuf@coredump.cx>

[+] Closed 1 file descriptor.
[+] Loaded 322 signatures from '/etc/p0f/p0f.fp'.
[+] Intercepting traffic on interface 'eth0'.
[+] Default packet filtering configured [+VLAN].
[+] Entered main event loop.
```

然后开启 Firefox 浏览器，并在 url 地址栏中输入客户端的 IP 地址，由于 Kali 自带的浏览器在启动时会加载相关页面，因此可以观察 p0f 监听到的信息，可以看到目标系统客户端 192.168.159.190 的操作系统类型为 Linux 2.2.x-3.x。

批注 [y5]: 这个 ip 是 Metasploitable2-Linux 的 ip。通过 nmap 扫描判断。

```

.-[ 192.168.159.131/43020 → 192.168.159.190/80 (syn) ]-
|
| client    = 192.168.159.131/43020
| os       = Linux 2.2.x-3.x
| dist     = 0
| params   = generic
| raw_sig  = 4:64+0:0:1460:mss*44,7:mss,sok,ts,nop,rs:at,id+0
|
|

```

Nmap 实现操作系统指纹识别是通过用 TCP/IP 协议栈的指纹进行远程操作系统探测来实现的，TCP/IP 协议栈指纹就是各个厂家，如微软和 RedHat 在编写自己的 TCP/IP 协议栈时，对协议栈做出了不同的解释，这些解释因具有独一无二的特性，故被称为“指纹”。Nmap 有 1500 多个已知操作系统的指纹信息，用“-O”参数可实现操作系统指纹识别功能，以本节中 Kali 虚拟机网络环境为例，命令为 `nmap -O 192.168.159.190`。

```

$ sudo nmap -O 192.168.159.190
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-27 15:39 CST
Nmap scan report for 192.168.159.190
Host is up (0.00050s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:0C:29:C9:1D:D7 (VMware)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 1.82 seconds

```

2.3.4 端口扫描

每个端口对应了一个网络服务及应用端的程序，通过端口扫描我们可以发现目标系统开放的端口、启用的服务，能够得到更具体的攻击面。

Metasploit 中提供了端口扫描功能模块，该功能属于辅助模块，具体的模块路径为 `modules/auxiliary/scanner/portscan/`，该路径下的子项目共有 `ack`、`ftpbounce`、`syn`、`tcp` 和 `xmas` 共 5 个。

```
msf6 > use auxiliary/scanner/portscan/
Matching Modules
#  Name                                     Disclosure Date  Rank  Check  Description
0  auxiliary/scanner/portscan/ack            normal         No     TCP ACK Firewall Scanner
1  auxiliary/scanner/portscan/ftpbounce      normal         No     FTP Bounce Port Scanner
2  auxiliary/scanner/portscan/syn            normal         No     TCP SYN Port Scanner
3  auxiliary/scanner/portscan/tcp            normal         No     TCP Port Scanner
4  auxiliary/scanner/portscan/xmas           normal         No     TCP Xmas Port Scanner
```

其中，`syn` 是通过使用发送 TCP SYN 标志的方式实现探测开放的端口目标，探测过程比较隐蔽，而且扫描速度会比较快。使用 `syn` 模块进行端口扫描时，首先用 `use auxiliary/scanner/portscan/syn` 启用端口扫描模块，然后使用 `set` 命令设置扫描的主机地址和线程个数，这里设置的主机地址为虚拟机的宿主机 IP 地址，然后使用 `run` 命令启动扫描，可看到主机 192.168.159.190 的 TCP 开启端口。

```
msf6 > use auxiliary/scanner/portscan/syn
msf6 auxiliary(scanner/portscan/syn) > set rhost 192.168.159.190
rhost => 192.168.159.190
msf6 auxiliary(scanner/portscan/syn) > run

[+] TCP OPEN 192.168.159.190:21
[+] TCP OPEN 192.168.159.190:22
[+] TCP OPEN 192.168.159.190:23
[+] TCP OPEN 192.168.159.190:25
[+] TCP OPEN 192.168.159.190:53
[+] TCP OPEN 192.168.159.190:80
[+] TCP OPEN 192.168.159.190:111
[+] TCP OPEN 192.168.159.190:139
```

用 `Nmap` 实现端口扫描，使用默认的扫描方式对目标的端口进行扫描，命令为 `nmap 192.168.159.190`，可以看到目标主机有 977 个关闭的端口，因为未加参数，默认只扫描 1000 个常见端口。


```
(kali@kali)-[~]
$ nmap 192.168.159.190
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-27 16:00 CST
Nmap scan report for 192.168.159.190
Host is up (0.033s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown

Nmap done: 1 IP address (1 host up) scanned in 1.34 seconds
```

指导书图

Nmap 默认的端口扫描方式是 TCPSYN 扫描，这种扫描方式的优点是执行得很快，如果扫描目标网络没有使用防火墙的话，每秒可以扫描数千个端口，而且这种扫描方式不易被注意到，能明确可靠地区分 open（开放的）、closed（关闭的）、和 filtered（被过滤的）状态。如果想要增加扫描范围，可以利用 -p 参数进行全端口扫描，命令为 **nmap** 192.168.159.190 -p 1-65535。


```
$ nmap 192.168.159.190 -p 1-65535
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-27 16:05 CST
Nmap scan report for 192.168.159.190
Host is up (0.0017s latency).
Not shown: 65505 closed tcp ports (conn-refused)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
3632/tcp  open  distccd
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
6697/tcp  open  ircs-u
8009/tcp  open  ajp13
8180/tcp  open  unknown
8787/tcp  open  msgsrvr
34906/tcp open  unknown
49757/tcp open  unknown
52289/tcp open  unknown
57197/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 5.15 seconds
```

指导书图

2.3.5 服务指纹识别

服务指纹识别主要是确定某个服务的版本信息，由于漏洞通常与服务的版本关联，因此服务指纹识别对后续的渗透测试也十分重要。

Amap 是一个服务枚举工具，使用这个工具可以识别正运行在一个指定的端口或一个端口范围上的应用程序。**Amap** 的工作原理是向某个端口发送触发的报文，将收到的响应与其数据库中的结果进行匹配，输出与之相匹配的应用程序信息。

Amap 在 Kali 中未默认安装，需使用 `apt-get install amap` 进行安装。注：实验环境中已安装。

```
(root@kali)~/home/kali
# apt-get install amap
正在读取软件包列表 ... 完成
正在分析软件包的依赖关系树
正在读取状态信息 ... 完成
下列软件包是自动安装的并且现在不需要了：
  hostapd libpython3.8-dev libreadline5 python3-pbkdf2 python3-pyric python3-roguehostapd python3.8-dev
使用 'apt autoremove' 来卸载它(它们)。
下列【新】软件包将被安装：
  amap
升级了 0 个软件包，新安装了 1 个软件包，要卸载 0 个软件包，有 1173 个软件包未被升级。
需要下载 68.2 kB 的归档。
解压后会消耗 181 kB 的额外空间。
获取:1 http://mirrors.neusoft.edu.cn/kali kali-rolling/main amd64 amap amd64 5.4-4kali2 [68.2 kB]
已下载 68.2 kB，耗时 3秒 (24.2 kB/s)
正在选中未选择的软件包 amap。
(正在读取数据库 ... 系统当前共安装有 262889 个文件和目录。)
准备解压 .../amap_5.4-4kali2_amd64.deb ...
正在解压 amap (5.4-4kali2) ...
正在设置 amap (5.4-4kali2) ...
正在处理用于 kali-menu (2020.4.0) 的触发器 ...
正在处理用于 man-db (2.9.3-2) 的触发器 ...
```

安装完成后，键入 **amap** 运行 **Amap**，其命令说明如下。

```
(root@kali)~/home/kali
# amap
amap v5.4 (c) 2011 by van Housen cv@thc.org www.thc.org/thc-amap
Syntax: amap [-A-B-P-W] [-lbusSHdqv] [-m] [-o <file>] [-D <file>] [-t/-T sec] [-c cons] [-C retries] [-p proto] [-i <file>] [target port [port] ...]
Modes:
  -A Map applications: send triggers and analyse responses (default)
  -B Just grab banners, do not send triggers
  -P No banner or application stuff - be a (full connect) port scanner
Options:
  -l Only send triggers to a port until 1st identification. Speedeeed!
  -b Use IPv6 instead of IPv4
  -B Print ascii banner of responses
  -i FILE Nmap machine readable outfile to read ports from
  -u Ports specified on commandline are UDP (default is TCP)
  -R Do NOT identify RPC service
  -H Do NOT send application triggers marked as potentially harmful
  -U Do NOT dump unrecognised responses (better for scripting)
  -d Dump all responses
  -v Verbose mode, use twice (or more!) for debug (not recommended :-))
  -q Do not report closed ports, and do not print them as unidentified
  -o FILE [-n] Write output to file FILE, -n creates machine readable output
  -C CONS Amount of parallel connections to make (default 32, max 256)
  -C RETRIES Number of reconnects on connect timeouts (see -T) (default 3)
  -T SEC Connect timeout on connection attempts in seconds (default 5)
  -t SEC Response wait timeout in seconds (default 5)
  -p PROTO Only send triggers for this protocol (e.g. ftp)
TARGET PORT The target address and port(s) to scan (additional to -i)
amap is a tool to identify application protocols on target ports.
Note: this version was NOT compiled with SSL support!
Usage hint: Options "-bqv" are recommended, add "-i" for fast/rush checks.
```

使用 **Amap** 对目标 80 端口的服务进行扫描，可以看到 80 端口开启了 HTTP 和 HTTP-Apache-2 服务。

```
(kali@kali)~[桌面]
$ amap 192.168.159.190 80
amap v5.4 (www.thc.org/thc-amap) started at 2022-03-27 15:10:32 - APPLICATION MAPPING mode

Protocol on 192.168.159.190:80/tcp matches http
Protocol on 192.168.159.190:80/tcp matches http-apache-2

Unidentified ports: none.

amap v5.4 finished at 2022-03-27 15:10:38
```

此外，也可通过 **Amap** 的“-b”参数查看接收到的服务标识信息，具体命令为 **amap 192.168.159.190 80 -b**，根据扫描的信息可以确定该目标机 80 端口运行的 Apache 服务版本和后端脚本语言 PHP 版本。

```
(kali@kali)~[桌面]
$ nmap 192.168.159.190 -b
nmap v5.4 (www.nmap.org) started at 2022-03-27 15:11:35 - APPLICATION MAPPING mode
Protocol on 192.168.159.190:80/tcp matches http - banner: HTTP/1.1 200 OK\r\nDate: Fri, 18 Mar 2022 22:04:39 GMT\r\nServer: Apache/2.2.8 (Ubuntu) DAV/2\r\nX-Powered-By: PHP/5.2.4-2ubuntu5.10\r\nContent-Length: 891\r\nConnection: close\r\nContent-Type: text/html\r\n\r\n<html>\r\n<head>\r\n<title>Metasploitable2 - Linux</title>\r\n</head>\r\n<body>\r\n<h1>Metasploitable2 - Linux</h1>\r\n</body>\r\n</html>\r\n\r\n</html>\r\n\r\nUnidentified ports: none.
nmap v5.4 finished at 2022-03-27 15:11:41
```

Nmap 的服务指纹识别也是通过将其收集到的端口信息与自身的数据库进行对比匹配实现的，服务版本查询可以用“-sV”参数实现。以本节中 Kali 虚拟机为例，具体的探测命令为 **nmap -sV 192.168.159.190**。

```
(kali@kali)~[桌面]
$ nmap -sV 192.168.159.190
Starting Nmap 7.92 ( https://nmap.org ) at 2022-03-27 15:14 CST
Nmap scan report for 192.168.159.190
Host is up (0.0000s latency)
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet         Linux telnetd
25/tcp    open  smtp           Postfix smtpd
53/tcp    open  domain         ISC BIND 9.4.2
80/tcp    open  http           Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind        2 (RPC #100000)
139/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn    Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec           netkit-rsh rexecd
513/tcp   open  login          OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi       GNU Classpath gmicregistry
1524/tcp  open  bindshell      Metasploitable root shell
2049/tcp  open  nfs            2-4 (RPC #100003)
2121/tcp  open  ftp           ProFTPD 1.3.1
3306/tcp  open  mysql          MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql     PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc            VNC (protocol 3.3)
6000/tcp  open  X11            (access denied)
6667/tcp  open  irc            UnrealIRCd
8009/tcp  open  ajp13          Apache Jserv (Protocol v1.3)
8180/tcp  open  http           Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.88 seconds
```

2.3.6 Web 目录扫描

在我们部署了网站之后有很多的敏感文件，比如说配置文件（.cfg）、数据文件（.sql）、目录文件（/backup/conf/admin）。但是有些网站如果配置出现问题，就会被攻击者攻击。这些配置的问题会导致数据库用户名和密码、服务器的用户名和密码、数据库的文件、网站源码等等信息都会被入侵。如果黑客获得了相应文件后，就能对网站进行进一步的攻击！

dirb 是 kali 下自带的 web 目录扫描工具，使用 dirsearch 对目标机器进行扫描，用法如下：

dirb http://192.168.159.190/ /usr/share/dirb/wordlists/big.txt

```
(root@kali)-[~]
# dirb http://192.168.159.190/ /usr/share/dirb/wordlists/big.txt

-----
DIRB v2.22
By The Dark Raver
-----

START_TIME: Tue Feb 21 22:21:31 2023
URL_BASE: http://192.168.159.190/
WORDLIST_FILES: /usr/share/dirb/wordlists/big.txt

-----

GENERATED WORDS: 20458

---- Scanning URL: http://192.168.159.190/ ----
+ http://192.168.159.190/cgi-bin/ (CODE:403|SIZE:296)
==> DIRECTORY: http://192.168.159.190/dav/
+ http://192.168.159.190/index (CODE:200|SIZE:891)
==> DIRECTORY: http://192.168.159.190/phpMyAdmin/
+ http://192.168.159.190/phpinfo (CODE:200|SIZE:48107)
+ http://192.168.159.190/server-status (CODE:403|SIZE:301)
==> DIRECTORY: http://192.168.159.190/test/
==> DIRECTORY: http://192.168.159.190/tikiwiki/
==> DIRECTORY: http://192.168.159.190/twiki/

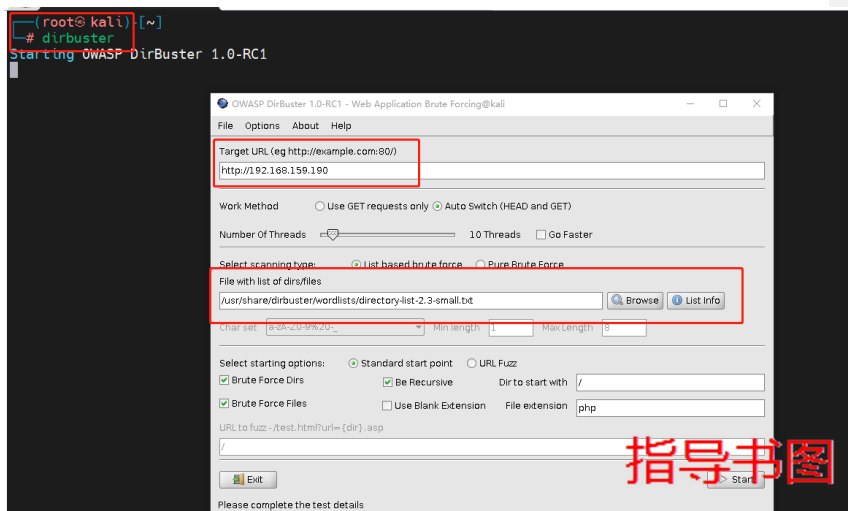
---- Entering directory: http://192.168.159.190/dav/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)
```

指导书图

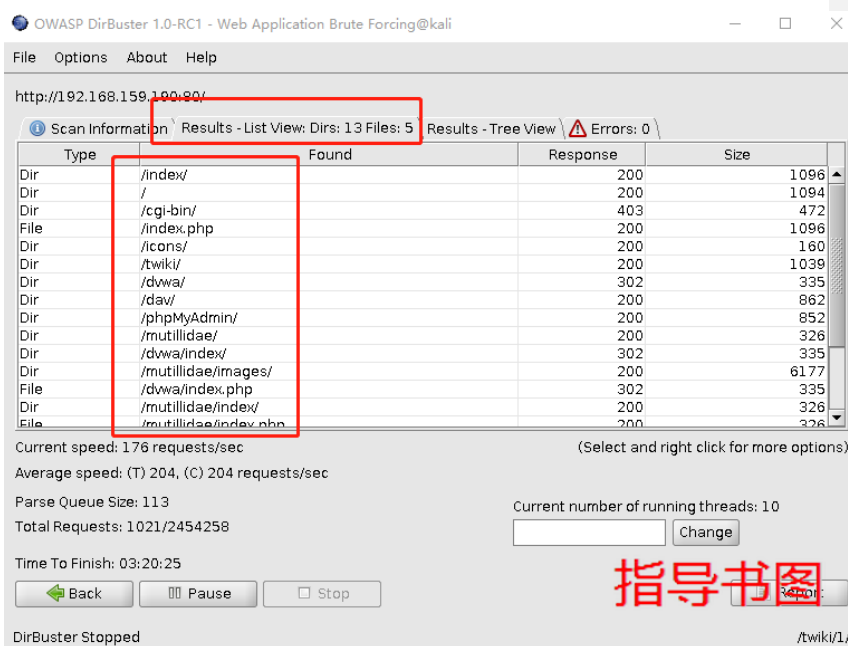
可以看到 mysql 数据库的管理组件 phpMyAdmin 路径泄露。

同样 dirbuster 可视化扫描工具，也是在 kali 中集成，使用 dirbuster 命令启动。

填入目标机器 url 和相应的爆破字典即可。工具自带的字典路径为 /usr/share/dirbuster/wordlists/，例如选择 directory-list-2.3-small.txt 进行 web 路径爆破。



看到爆破到的 web 路径与其他敏感文件。



2.4 总结与思考

2.4.1 实训总结

这部分内容是学习信息收集相关工具的使用，主要包括：

- 使用工具实现活跃主机扫描、操作系统指纹识别、端口扫描、服务指纹识别和 Web 目录扫描。

2.4.2 思考题

除了书本上介绍的活跃主机扫描、操作系统指纹识别、端口扫描、服务指纹识别和 Web 目录扫描这些方向外，你还知道哪些主动信息收集的方向？